

Luiss

Libera Università Internazionale
degli Studi Sociali Guido Carli

Cybersecurity & Privacy Regulations

Data Privacy and Security

Data Science and Management (DASMA)

LUISS



Why Regulation Exists



Why cybersecurity incidents become legal problems

A breach is rarely only a technical outage. It immediately creates at least four parallel problems:

- **Operational:** systems fail, data becomes unavailable, customers cannot use the service
- **Economic:** incident response, forensics, legal advice, customer support, and downtime cost money
- **Reputational:** partners and users infer weak governance, not just bad luck
- **Regulatory:** organizations may need to notify authorities, affected people, customers, and sector regulators

Why cybersecurity incidents become legal problems

A breach is rarely only a technical outage. It immediately creates at least four parallel problems:

- **Operational:** systems fail, data becomes unavailable, customers cannot use the service
- **Economic:** incident response, forensics, legal advice, customer support, and downtime cost money
- **Reputational:** partners and users infer weak governance, not just bad luck
- **Regulatory:** organizations may need to notify authorities, affected people, customers, and sector regulators

Security controls are judged after the incident with hindsight. If the organization cannot show a reasonable decision process, documentation, and escalation path, regulators usually treat the failure as a governance problem, not only an engineering mistake.

Why states regulate digital systems

Market failures

- Users cannot inspect backend data practices
- Vendors may externalize security costs onto customers
- Network effects make it hard to switch providers
- A single weak supplier can expose many downstream organizations

Public-interest reasons

- Healthcare, energy, finance, and transport affect society at scale
- Privacy violations can distort elections, labor markets, and insurance decisions
- Cross-border data flows need common legal rules
- Cyber incidents increasingly have geopolitical consequences

Incidents that changed the legal agenda

Some incidents matter because they changed what lawmakers and regulators considered politically urgent:

- **Cambridge Analytica** made profiling, consent, and platform governance visible to the public
- **Equifax** showed that one patching failure could expose national-scale identity data
- **Colonial Pipeline** and major ransomware cases connected cyber risk to critical infrastructure and national security
- Large cookie-banner and ad-tech cases showed that privacy violations can be systematic business models, not isolated bugs

Incidents that changed the legal agenda

Some incidents matter because they changed what lawmakers and regulators considered politically urgent:

- **Cambridge Analytica** made profiling, consent, and platform governance visible to the public
- **Equifax** showed that one patching failure could expose national-scale identity data
- **Colonial Pipeline** and major ransomware cases connected cyber risk to critical infrastructure and national security
- Large cookie-banner and ad-tech cases showed that privacy violations can be systematic business models, not isolated bugs

A useful pattern: regulation often follows repeated, visible failures where the cost of inaction becomes politically harder to defend than the cost of compliance.

Cambridge Analytica (2014–2018): profiling meets politics

A Facebook personality quiz app (*thisisyourdigitallife*, 2014) collected data not only from its 270,000 users but also from **all of their friends** – about **87 million profiles** in total – under Facebook's permissive API rules of the time.

The data was passed to **Cambridge Analytica**, a political-consulting firm that used it for behavioral micro-targeting in the **2016 US presidential campaign** and the **Brexit** referendum.

Regulatory and political consequences:

- **FTC** fined Facebook **USD 5 billion** (2019) – the largest privacy fine in US history at the time
- UK **ICO** fined Facebook £500,000, hitting the ceiling of the pre-GDPR regime
- Profiling, consent, and platform governance became a **mainstream political issue**, not a niche expert debate
- Accelerated EU work on **political advertising rules** and the **Digital Services Act** (DSA)

Equifax (2017): one unpatched CVE, a nation exposed

Equifax is one of the three major US credit bureaus. In 2017 it failed to patch a known Apache Struts vulnerability (**CVE-2017-5638**) for which a fix had been available for **two months**.

Attackers exfiltrated records on **147 million Americans** – roughly half the US adult population – including **Social Security Numbers**, dates of birth, addresses, and some driver's-license numbers.

Regulatory and political consequences:

- Global settlement of **USD 700 million** with the FTC, CFPB, and 50 US states/territories
- Congressional hearings; CEO resignation; sustained media coverage
- Boosted adoption of **state breach-notification laws** and, eventually, the **SEC 4-business-day disclosure rule** (2023)
- Became the textbook example that a single missed patch can turn into a national identity-theft crisis – and that **vulnerability management is a regulated activity**, not just an ops hygiene task

Colonial Pipeline (2021): ransomware becomes national security

In May 2021 the **DarkSide** ransomware group encrypted the corporate IT systems of **Colonial Pipeline**, which carries about **45% of the US East Coast's fuel**.

The company shut the pipeline for **six days** as a precaution, triggering panic-buying and fuel shortages from Georgia to New Jersey. Colonial paid **USD 4.4 million** in Bitcoin; the US DOJ later recovered roughly half via seizure of the attackers' wallet.

Regulatory and political consequences:

- **TSA Security Directives** imposed mandatory cybersecurity requirements on pipeline operators within weeks
- **Executive Order 14028** (May 2021) on federal supply-chain cybersecurity, zero-trust, and **SBOM** (Software Bill of Materials) adoption
- **CIRCA** (Cyber Incident Reporting for Critical Infrastructure Act, 2022): mandatory incident reporting for US critical-infrastructure entities
- Reinforced the EU argument behind **NIS2** and **CER**: cyber risk to critical sectors is a **national-security** issue, not only a commercial one

Cookies and ad-tech: when the violation *is* the business model

Unlike the previous incidents, these are not single breaches but **systematic practices** that regulators eventually ruled unlawful:

- **Planet49** (CJEU, 2019): pre-ticked cookie-consent boxes are **not valid consent** under GDPR and ePrivacy
- **IAB TCF** (Transparency and Consent Framework), the standard powering most European cookie banners, was ruled unlawful by the **Belgian DPA** in 2022
- **Google Analytics** use was declared non-compliant with GDPR by the **Austrian, French, and Italian** DPAs in 2022, because of US surveillance law exposure after the **Schrems II** judgment (CJEU, 2020)
- **Meta** fined **EUR 1.2 billion** by the Irish DPC (2023) for unlawful EU → US personal-data transfers
- **TikTok** fined EUR 345M (2023) over children's data; **Amazon** fined EUR 746M (2021) over ad targeting

These cases showed that non-compliance could be **baked into an entire industry's revenue model** – and pushed the EU and US to negotiate the **EU-US Data Privacy Framework** (2023).

Privacy, cybersecurity, and product security are different layers

Privacy / data protection

- When can personal data be collected?
- For which purpose can it be reused?
- What rights does the individual have?

Cybersecurity

- Are systems resilient, monitored, and recoverable?
- Is access controlled?
- Is incident response organized and documented?

Product / software security

- Was the product designed securely?
- Are vulnerabilities handled and patched?
- Are manufacturers accountable after release?

Core actors you must distinguish

- **Data subject**: the natural person the data is about
- **Controller**: determines the purpose and means of processing
- **Processor**: processes personal data on behalf of a controller
- **Supervisory authority / regulator**: enforces compliance
- **DPO** (Data Protection Officer): internal privacy governance role; mandatory in certain GDPR contexts
- **CISO** (Chief Information Security Officer): leads security risk management and incident response
- **Management body / board**: increasingly accountable directly for cybersecurity and privacy governance

Core actors you must distinguish

- **Data subject**: the natural person the data is about
- **Controller**: determines the purpose and means of processing
- **Processor**: processes personal data on behalf of a controller
- **Supervisory authority / regulator**: enforces compliance
- **DPO** (Data Protection Officer): internal privacy governance role; mandatory in certain GDPR contexts
- **CISO** (Chief Information Security Officer): leads security risk management and incident response
- **Management body / board**: increasingly accountable directly for cybersecurity and privacy governance

A repeated compliance mistake is assuming that outsourcing processing also outsources accountability.
In most regimes, it does not.

Legal Concepts You Need First



Territorial scope: why a foreign law may still apply

Modern digital regulation is frequently **extraterritorial**. The law may apply because of what you do, whom you target, or where the impact occurs.

Typical triggers:

- Offering goods or services to people in the jurisdiction
- Monitoring behavior in that jurisdiction
- Operating critical services or infrastructure there
- Serving a regulated sector such as healthcare, finance, or government

Not all data is regulated in the same way

Personal data

Any information relating to an identifiable natural person:

- name
- email
- IP address in many contexts
- device identifiers
- location data

Pseudonymized data

Identifiers are replaced, but re-identification is still possible with extra information.

This is safer than raw data, but usually still regulated.

Anonymized data

No realistic route back to a person remains.

True anonymization is difficult, especially with rich behavioral datasets.

Sensitive categories trigger stricter rules

Some data types create higher risks of discrimination, coercion, or long-term harm. That is why many legal systems add stricter conditions for:

- health data
- biometric identifiers
- genetic data
- political opinions
- religious beliefs
- sexual orientation
- data about children

Sensitive categories trigger stricter rules

Some data types create higher risks of discrimination, coercion, or long-term harm. That is why many legal systems add stricter conditions for:

- health data
- biometric identifiers
- genetic data
- political opinions
- religious beliefs
- sexual orientation
- data about children

Do not reduce this to a checkbox exercise. The key question is not only whether data is labeled *sensitive*, but whether misuse could materially alter a person's opportunities, insurance, employment, safety, or dignity.

Lawful processing requires a justification

In privacy law, processing is usually forbidden **unless** there is a valid legal basis.

Common examples:

- **Consent**: valid only if specific, informed, and freely given
- **Contract**: needed to perform a service requested by the user
- **Legal obligation**: e.g., accounting, tax, regulatory reporting
- **Public task**: exercised by public bodies or delegated public functions
- **Legitimate interests**: available only after balancing organizational need against the individual's rights

Individual rights are operational requirements

Rights typically granted

- access
- correction
- deletion
- objection
- portability
- limits on automated decisions

What that means technically

- data inventories must be accurate
- identity verification is needed
- deletion must propagate to downstream systems when possible
- request deadlines require workflow automation

The EU Regulatory Model



The EU uses a layered regulatory architecture

The EU does not try to solve everything with one law. It combines multiple layers:

- **GDPR** (General Data Protection Regulation) – personal-data processing rights and obligations
- **ePrivacy Directive** – communications confidentiality and device-level tracking (*revision pending as ePrivacy Regulation*)
- **NIS2** (Network and Information Security Directive 2) – cybersecurity governance and incident reporting
- **Cybersecurity Act** – gives ENISA a permanent mandate and creates EU-wide certification frameworks
- **DORA** (Digital Operational Resilience Act) – ICT risk management for financial entities
- **CRA** (Cyber Resilience Act) – product security obligations for connected hardware and software
- **AI Act** (Artificial Intelligence Act) – risk-based governance for AI systems

GDPR: what it is really about

GDPR – the General Data Protection Regulation (Regulation (EU) 2016/679) – is not only a *cookie law* and not only a fine mechanism. Its core design goal is to force organizations to justify and discipline personal-data processing.

The regulation is built around six layers:

- **Principles** (Art. 5): lawfulness, fairness, transparency, purpose limitation, data minimisation, accuracy, storage limitation, integrity and confidentiality, accountability
- **Lawful bases** (Art. 6): the processing must have a legal ground
- **Transparency**: privacy notices must be clear, specific, and accessible
- **Individual rights** (Arts. 15–22): access, rectification, erasure, portability, objection, and more
- **Security and accountability** (Arts. 24–32): demonstrable controls, records, and governance
- **Enforcement** (Arts. 77–83): supervisory authorities, DPAs, fines

GDPR: what it is really about

GDPR – the General Data Protection Regulation (Regulation (EU) 2016/679) – is not only a *cookie law* and not only a fine mechanism. Its core design goal is to force organizations to justify and discipline personal-data processing.

The regulation is built around six layers:

- **Principles** (Art. 5): lawfulness, fairness, transparency, purpose limitation, data minimisation, accuracy, storage limitation, integrity and confidentiality, accountability
- **Lawful bases** (Art. 6): the processing must have a legal ground
- **Transparency**: privacy notices must be clear, specific, and accessible
- **Individual rights** (Arts. 15–22): access, rectification, erasure, portability, objection, and more
- **Security and accountability** (Arts. 24–32): demonstrable controls, records, and governance
- **Enforcement** (Arts. 77–83): supervisory authorities, DPAs, fines

Lawfulness, fairness, transparency means the organization must be able to explain what it is doing in terms a regulator and an ordinary person can both understand.

GDPR: what it is really about

GDPR – the General Data Protection Regulation (Regulation (EU) 2016/679) – is not only a *cookie law* and not only a fine mechanism. Its core design goal is to force organizations to justify and discipline personal-data processing.

The regulation is built around six layers:

- **Principles** (Art. 5): lawfulness, fairness, transparency, purpose limitation, data minimisation, accuracy, storage limitation, integrity and confidentiality, accountability
- **Lawful bases** (Art. 6): the processing must have a legal ground
- **Transparency**: privacy notices must be clear, specific, and accessible
- **Individual rights** (Arts. 15–22): access, rectification, erasure, portability, objection, and more
- **Security and accountability** (Arts. 24–32): demonstrable controls, records, and governance
- **Enforcement** (Arts. 77–83): supervisory authorities, DPAs, fines

Lawfulness, fairness, transparency means the organization must be able to explain what it is doing in terms a regulator and an ordinary person can both understand.

Purpose limitation and data minimization mean *collect everything now, decide later* is usually not defensible.

GDPR: scope, actors, and sanctions

Scope

- applies to personal data of natural persons
- covers controllers/processors established in the EU
- can also apply to non-EU entities offering goods/services into the EU
- can also apply where behavior in the EU is monitored

Key actors

- controller
- processor
- joint controllers
- EU representative in some extra-territorial cases
- DPO in specified scenarios

Sanctions

- corrective orders
- processing bans
- audits and investigations
- administrative fines up to 20M EUR or 4% of global turnover for the most serious infringements

GDPR: scope, actors, and sanctions

Scope

- applies to personal data of natural persons
- covers controllers/processors established in the EU
- can also apply to non-EU entities offering goods/services into the EU
- can also apply where behavior in the EU is monitored

Key actors

- controller
- processor
- joint controllers
- EU representative in some extra-territorial cases
- DPO in specified scenarios

Sanctions

- corrective orders
- processing bans
- audits and investigations
- administrative fines up to 20M EUR or 4% of global turnover for the most serious infringements

The sanction mechanism matters because boards understand turnover-based fines immediately. GDPR was designed to be impossible for large organizations to ignore as a minor compliance nuisance.

GDPR duties that translate into engineering work

A few GDPR duties repeatedly force concrete system-level and governance changes:

- **Art. 28 processor governance**: written contracts with processors and sub-processors specifying instructions, security, and audit rights
- **RoPA** (Records of Processing Activities, Art. 30): a live inventory of what data is processed, why, by whom, and for how long
- **Security of processing** (Art. 32): access control, encryption, logging, resilience, and restore capability must be justified by a documented risk assessment
- **72-hour breach notification** (Art. 33): a supervisory authority must be notified within 72 hours of *discovering* a personal data breach – not 72 hours after containment
- **Data subject rights fulfillment** (Arts. 15–22): deletion, portability, and objection require queryable, governable, and auditable data flows
- **DPIA** (Data Protection Impact Assessment, Art. 35): processing that is 'likely to result in a high risk' must be assessed *before* deployment

GDPR duties that translate into engineering work

A few GDPR duties repeatedly force concrete system-level and governance changes:

- **Art. 28 processor governance**: written contracts with processors and sub-processors specifying instructions, security, and audit rights
- **RoPA** (Records of Processing Activities, Art. 30): a live inventory of what data is processed, why, by whom, and for how long
- **Security of processing** (Art. 32): access control, encryption, logging, resilience, and restore capability must be justified by a documented risk assessment
- **72-hour breach notification** (Art. 33): a supervisory authority must be notified within 72 hours of *discovering* a personal data breach – not 72 hours after containment
- **Data subject rights fulfillment** (Arts. 15–22): deletion, portability, and objection require queryable, governable, and auditable data flows
- **DPIA** (Data Protection Impact Assessment, Art. 35): processing that is 'likely to result in a high risk' must be assessed *before* deployment

Mental model: GDPR is not only a legal review at launch. It is a permanent requirement that data architecture, vendor management, and incident response stay explainable over time.

Where GDPR compliance typically drifts over time

Even organizations that were compliant at launch routinely discover gaps later. The recurring patterns:

- **Retention drift:** data is kept far beyond its stated purpose; deletion is inconsistent across replicas and backups
- **Stale RoPA:** records describe an architecture that was replaced months ago
- **Legacy processor contracts:** vendor agreements pre-dating GDPR still lack the mandatory Art. 28 clauses
- **DPIA gaps:** high-risk features ship without anyone recognizing that a DPIA was required
- **Rights fulfillment bottlenecks:** no clear workflow, identity verification adds friction, and the one-month deadline slips
- **Undocumented security rationale:** controls exist, but the risk reasoning that would justify them to a regulator does not

Where GDPR compliance typically drifts over time

Even organizations that were compliant at launch routinely discover gaps later. The recurring patterns:

- **Retention drift:** data is kept far beyond its stated purpose; deletion is inconsistent across replicas and backups
- **Stale RoPA:** records describe an architecture that was replaced months ago
- **Legacy processor contracts:** vendor agreements pre-dating GDPR still lack the mandatory Art. 28 clauses
- **DPIA gaps:** high-risk features ship without anyone recognizing that a DPIA was required
- **Rights fulfillment bottlenecks:** no clear workflow, identity verification adds friction, and the one-month deadline slips
- **Undocumented security rationale:** controls exist, but the risk reasoning that would justify them to a regulator does not

The architectural point: GDPR changes system design, governance, vendor management, and user workflows *simultaneously* – and keeps changing them, because the business and the data keep changing.

Cross-border transfers are a separate compliance layer

GDPR restricts transfers of personal data outside the EEA (European Economic Area) unless the destination country or the transfer arrangement meets adequate protection standards.

Key transfer mechanisms:

- **Adequacy decision** (Art. 45): the European Commission has formally determined the destination provides equivalent protection (e.g., UK, Japan, South Korea, parts of the US under EU-US Data Privacy Framework)
- **SCCs** (Standard Contractual Clauses, Art. 46): pre-approved contract clauses that bind exporter and importer to GDPR-equivalent obligations
- **BCRs** (Binding Corporate Rules, Art. 47): approved internal group-wide policies that enable intra-group transfers across multinational organizations

A **TIA** (Transfer Impact Assessment) is increasingly expected: even with SCCs in place, the exporter must assess whether the destination country's surveillance laws undermine the protection the clauses provide.

ePrivacy matters because tracking is not a side issue

The **ePrivacy Directive** (2002/58/EC, amended 2009) governs communications confidentiality and technologies that store or access information on user devices.

A replacement **ePrivacy Regulation** has been under negotiation since 2017 and remains pending. Until it is adopted, the Directive continues to apply – implemented differently across Member States.

Practically, ePrivacy rules affect:

- cookies, local storage, and SDKs that access device storage
- advertising identifiers and fingerprinting
- telemetry and tracking pixels
- direct marketing via email, SMS, and automated calls
- traffic and location metadata about who communicated with whom, when, and from where

NIS2 is about cyber governance, not privacy rights

NIS2 – the Network and Information Security Directive 2 (Directive (EU) 2022/2555) – replaces the original NIS Directive and significantly expands the scope and stringency of EU cybersecurity obligations.

Key themes:

- **Broader scope:** more sectors are covered; a new category of 'important entities' joins the existing 'essential entities'
- **Management accountability:** senior management can be held personally liable for NIS2 compliance failures
- **Mandatory minimum measures:** a defined set of risk-management measures is now required, not just recommended
- **Stricter incident reporting:** structured and time-sensitive reporting obligations (early warning → notification → final report)
- **Supply-chain security:** organizations must address cyber risks in their supplier and service-provider relationships

NIS2 is about cyber governance, not privacy rights

NIS2 – the Network and Information Security Directive 2 (Directive (EU) 2022/2555) – replaces the original NIS Directive and significantly expands the scope and stringency of EU cybersecurity obligations.

Key themes:

- **Broader scope:** more sectors are covered; a new category of 'important entities' joins the existing 'essential entities'
- **Management accountability:** senior management can be held personally liable for NIS2 compliance failures
- **Mandatory minimum measures:** a defined set of risk-management measures is now required, not just recommended
- **Stricter incident reporting:** structured and time-sensitive reporting obligations (early warning → notification → final report)
- **Supply-chain security:** organizations must address cyber risks in their supplier and service-provider relationships

NIS2 and GDPR often meet in the same incident, but they ask different questions. GDPR asks whether personal-data handling was lawful and appropriately protected; NIS2 asks whether the organization managed cyber risk and incident response as a covered entity should.

NIS2: who is in scope and what changes operationally

Who is covered

- essential and important entities
- many sectors expanded beyond original NIS
- size thresholds matter in many cases
- digital providers and supply-chain actors can also become relevant

What changes operationally

- the board must **approve and oversee** cybersecurity risk measures – and can be held personally liable
- registration with national competent authorities becomes a precondition to operate
- supervisors can perform **on-site inspections, audits, and security scans**
- non-compliance exposes entities to fines scaled to turnover (up to 2% for essential entities)
- vendor selection must factor in cyber risk, not just price and SLA

NIS2 minimum measures and reporting logic

NIS2 does not ask only for a firewall and an antivirus. It asks for an organized risk-management system.

Typical measures include:

- risk analysis and security policies
- incident handling procedures
- business continuity, backup, and crisis management
- supply-chain security
- secure development and vulnerability handling
- policies for assessing the effectiveness of measures
- basic cyber hygiene, training, and where appropriate cryptography and access control

Reporting logic is also more structured: an early warning can be expected in about 24 hours, a fuller notification around 72 hours, and a final report later, often around one month depending on national implementation.

NIS2 minimum measures and reporting logic

NIS2 does not ask only for a firewall and an antivirus. It asks for an organized risk-management system.

Typical measures include:

- risk analysis and security policies
- incident handling procedures
- business continuity, backup, and crisis management
- supply-chain security
- secure development and vulnerability handling
- policies for assessing the effectiveness of measures
- basic cyber hygiene, training, and where appropriate cryptography and access control

Reporting logic is also more structured: an early warning can be expected in about 24 hours, a fuller notification around 72 hours, and a final report later, often around one month depending on national implementation.

This is why NIS2 is not just a legal text for lawyers. If the organization cannot classify incidents quickly and preserve facts early, it cannot comply.

Cybersecurity Act: ENISA plus certification

ENISA: the institutional anchor

ENISA (European Union Agency for Cybersecurity) receives a permanent mandate under the Act:

- supports EU-wide cybersecurity policy and legislation
- coordinates operational cooperation and crisis response
- publishes threat landscapes, guidelines, and best-practice reports
- supports Member States in building national cybersecurity capacity

EU cybersecurity certification framework

The Act empowers the European Commission and ENISA to create sector-specific certification schemes:

- products and services can be certified against a recognized EU scheme
- three assurance levels: **basic, substantial, high**
- improves comparability and reduces fragmentation across Member States
- in some sectors or product categories, certification may become mandatory

Cybersecurity Act: certification is structured, not binary

The three assurance levels correspond to the threat model and the consequences of failure:

Level	Threat addressed	Evidence required
Basic	Known, lower-sophistication threats	Self-assessment by manufacturer
Substantial	Significant capabilities, including some state-level	Third-party review
High	Advanced persistent threats, state actors	Stricter third-party testing and audit

The level required for a product or service depends on the scheme. Some schemes are sector-specific (e.g., cloud services, consumer IoT). The EU Cloud Certification Scheme (EUCS) is one early example.

DORA: why the financial sector got a dedicated regime

Finance depends on uptime, integrity, and third-party **ICT** (Information and Communication Technology) providers. **DORA** (Digital Operational Resilience Act, Regulation (EU) 2022/2554) responds to that by standardizing expectations across EU financial entities. It applies to:

- banks, investment firms, and payment institutions
- insurance and reinsurance undertakings
- crypto-asset service providers
- critical ICT third-party providers (designated separately)

Core pillars of DORA:

- **ICT risk management**: documented framework, management-body oversight
- **Incident reporting**: classification and structured notification to competent authorities
- **Digital operational resilience testing**: regular tests, including advanced TLPT (Threat-Led Penetration Testing) for some entities
- **Third-party risk**: registers of ICT providers, contractual requirements, and concentration risk oversight

DORA in practice: what financial entities actually need

DORA is detailed because the financial sector already depends heavily on shared ICT providers and cannot tolerate chaotic incident handling. Translated into day-to-day consequences:

- The **management body**, not just the CISO, signs off on the ICT risk framework and is accountable to supervisors
- Incident classification becomes a **regulated taxonomy**: what counts as 'major' is not left to internal judgement
- Resilience testing moves from good practice to **mandatory schedule**, with advanced TLPT for the largest entities
- Cloud and ICT vendor choices become a **supervised decision**: registers, exit strategies, and concentration risk must be documented
- Critical ICT third parties (e.g. hyperscalers) can be placed under **direct EU oversight**, regardless of their own sector

CRA and AI Act: what they regulate

CRA (Cyber Resilience Act)

Applies to **products with digital elements** placed on the EU market:

- covers both hardware and standalone software (including apps)
- manufacturers must meet essential security requirements *before* placing products on the market
- vulnerability handling and security updates must continue throughout the product support period
- serious incidents and actively exploited vulnerabilities must be reported to ENISA
- enforcement: national market surveillance authorities; CE marking implications

AI Act (Artificial Intelligence Act)

Applies to **providers and deployers** of AI systems in the EU:

- risk tiers: unacceptable risk (prohibited), high risk, limited risk, minimal risk
- high-risk systems (e.g., biometric ID, employment decisions, critical infrastructure) face the heaviest obligations
- prohibited practices include real-time remote biometric surveillance in public spaces (with limited exceptions)
- obligations include: conformity assessment, technical documentation, human oversight, data governance
- a new **EU AI Office** oversees enforcement for general-purpose AI models

CRA and AI Act: who is regulated and what compliance looks like

CRA: regulated parties and process

- **Manufacturers** bear the primary duties (security-by-design, documentation, CE-marking, vulnerability handling, ENISA notifications)
- **Importers** and **distributors** must verify that products are CE-marked and must act when they learn a product is non-compliant
- **Open-source software** is generally out of scope – unless it is supplied in the course of a commercial activity
- Conformity path depends on product class: **self-assessment** for most products, **third-party assessment** for 'important' and 'critical' categories

AI Act: regulated parties and process

- **Providers** (who develop/deploy the AI system): bear the primary compliance burden for high-risk systems
- **Deployers** (who use AI systems in their operations): additional duties, especially in high-risk contexts
- Conformity assessment: self-assessment for most high-risk systems; third-party for specific categories (e.g., biometrics)
- Providers of **general-purpose AI models** (e.g., large language models) face separate transparency and safety evaluation obligations

EU enforcement is distributed, not centralized

EU regulatory enforcement is deliberately distributed – no single actor holds all the power.

- **National DPAs** (Data Protection Authorities): enforce GDPR; each Member State has one; the lead DPA for cross-border cases is where the controller is established
- **EDPB** (European Data Protection Board): coordinates interpretation, issues binding decisions in cross-border disputes, and publishes guidelines
- **ENISA** (EU Agency for Cybersecurity): supports policy and certification, but does not issue GDPR or NIS2 fines
- **National competent authorities**: implement NIS2 obligations sector by sector
- **National competent authorities / ESAs**: ESAs (European Supervisory Authorities – EBA, ESMA, EIOPA) play a role in DORA enforcement
- Courts remain important: supervisory decisions can be challenged via judicial review

The US Regulatory Model



The US approach is fragmented by sector, state, and agency

There is no single US federal equivalent of GDPR. Instead, compliance often means combining:

- sector-specific federal laws
- state privacy statutes
- agency enforcement theories
- contractual security requirements
- influential standards such as NIST

HIPAA: narrow scope, strong expectations

HIPAA (Health Insurance Portability and Accountability Act, 1996) applies to **covered entities** – healthcare providers, health plans, and healthcare clearinghouses – and their **business associates** that create, receive, maintain, or transmit **PHI** (Protected Health Information) on their behalf.

Two things make HIPAA distinctive:

- It is **not one rule but three interlocking operational regimes** (Privacy, Security, Breach Notification), detailed in the next slide
- The contractual hinge is the **BAA** (Business Associate Agreement): any vendor touching PHI must sign one, which extends HIPAA liability down the supply chain

HIPAA is really three operational regimes

Privacy Rule

- governs permitted uses and disclosures of PHI (Protected Health Information)
- minimum necessary standard: access only the PHI needed for the task
- patients have rights: access to their records, amendments, and an accounting of disclosures
- covered entities must provide a **Notice of Privacy Practices (NPP)**

Security Rule

Applies to **ePHI** (electronic Protected Health Information). Required safeguards:

- **Administrative:** risk analysis, security officer, workforce training, access management
- **Physical:** facility access controls, workstation security, device and media controls
- **Technical:** access controls, audit controls, integrity controls, transmission security (encryption)
- Required vs. addressable: some controls are mandatory; others must be implemented or their exclusion justified

Breach Notification Rule

When unsecured PHI is improperly accessed or disclosed:

- **Affected individuals** must be notified within 60 days of discovery
- **HHS** (Dept. of Health and Human Services) must be notified; large breaches (≥ 500 affected) appear on the public 'Wall of Shame'
- **Media** must be notified if the breach affects ≥ 500 residents of a single state
- The **HITECH Act** strengthened these rules and increased civil penalties

GLBA and FTC-style enforcement focus on business controls

GLBA (Gramm-Leach-Bliley Act)

Applies to **financial institutions** sharing **NPI** (Non-Public Personal Information):

- Privacy Rule: consumers must be notified about data sharing practices
- **Safeguards Rule**: requires a written information-security program
- Risk assessment → safeguard selection → testing → vendor oversight → incident response
- Updated FTC Safeguards Rule (2023): more prescriptive security requirements, including encryption and MFA

FTC (Federal Trade Commission) approach

The FTC uses its **Section 5 authority** (unfair or deceptive acts or practices) to regulate data security and privacy:

- misrepresentations in privacy notices or terms of service
- weak security controls that are inconsistent with public promises made to users
- 'unfair' practices that cause consumer harm even without a specific privacy law
- primary enforcement tool: consent orders imposing multi-year third-party audit requirements
- no-fault enforcement is possible: the FTC can act based on outcomes, not intent

CCPA / CPRA: what makes California operationally important

CCPA (California Consumer Privacy Act, 2018), strengthened by **CPRA** (California Privacy Rights Act, 2020), creates consumer-rights workflows far closer to European privacy law than older US notice-only models.

Core elements:

- notice at collection: what categories are collected, why, and with whom they are shared
- rights to **know**, **delete**, and **correct** personal information
- **opt-out right** for the *sale* and *sharing* of personal information (including for targeted advertising)
- heightened restrictions on **sensitive personal information** (SPI): race, health, precise geolocation, biometrics, etc.
- **service provider** / **contractor restrictions**: functional equivalents of GDPR processor obligations
- **CPPA** (California Privacy Protection Agency): dedicated enforcement authority created by CPRA
- Thresholds apply: businesses meeting any of – 100K+ consumer records, 25%+ revenue from selling data, or \$25M annual gross revenue

CCPA / CPRA: what makes California operationally important

CCPA (California Consumer Privacy Act, 2018), strengthened by **CPRA** (California Privacy Rights Act, 2020), creates consumer-rights workflows far closer to European privacy law than older US notice-only models.

Core elements:

- notice at collection: what categories are collected, why, and with whom they are shared
- rights to **know**, **delete**, and **correct** personal information
- **opt-out right** for the *sale* and *sharing* of personal information (including for targeted advertising)
- heightened restrictions on **sensitive personal information** (SPI): race, health, precise geolocation, biometrics, etc.
- **service provider** / **contractor restrictions**: functional equivalents of GDPR processor obligations
- **CPPA** (California Privacy Protection Agency): dedicated enforcement authority created by CPRA
- Thresholds apply: businesses meeting any of – 100K+ consumer records, 25%+ revenue from selling data, or \$25M annual gross revenue

For engineering teams, the practical impact is simple: once California-style rights exist, one internal privacy workflow is often reused across multiple states even if the statutes are not identical.

State privacy laws: California matters, but it is not alone

California set the template, but around twenty US states have now passed their own consumer-privacy statutes – Virginia, Colorado, Connecticut, Utah, Texas, Oregon, and others – and more are in the pipeline.

They broadly share the CCPA-style rights (know / delete / correct / opt-out), but diverge on details that matter for implementation:

- **thresholds:** revenue, number of records, or share of revenue from data sales
- **definitions of 'sale' and 'share':** especially around targeted advertising
- **sensitive-data regime:** opt-in vs. opt-out, and which categories count
- **opt-out signals:** some states require honoring browser-level Global Privacy Control
- **enforcement:** most rely on the state AG; California also has the dedicated CPPA
- **private right of action:** generally absent, except narrowly in California

For engineering teams, the net effect is usually a single internal privacy workflow tuned to the strictest applicable state, rather than one implementation per statute.

SEC, FISMA, and FedRAMP show another US pattern

In the US, compliance obligations also flow from market oversight and government procurement:

- **SEC** (Securities and Exchange Commission): public companies must disclose material cybersecurity incidents within 4 business days (Form 8-K); annual disclosure of governance and risk management practices (Form 10-K)
- **FISMA** (Federal Information Security Modernization Act): requires federal agencies and their contractors to implement NIST-based security controls; each agency designates a **CISO** and reports to OMB
- **FedRAMP** (Federal Risk and Authorization Management Program): standardized cloud security authorization process; cloud providers must be FedRAMP authorized to sell to federal agencies

In practice, contracts and audits enforce these duties as tightly as the statutes themselves – large enterprise and government customers routinely require alignment as a procurement condition.

NIST and procurement shape US compliance even without one federal privacy law

The US often regulates through guidance, procurement requirements, and sector pressure rather than omnibus legislation.

- **NIST** (National Institute of Standards and Technology) SP 800-series publications define security and privacy controls widely adopted as benchmarks
- **NIST CSF** (Cybersecurity Framework) 2.0 is referenced by regulators, insurers, and enterprise customers even when there is no direct federal mandate
- **NIST SP 800-53** provides a comprehensive control catalog used across federal agencies and increasingly in private-sector compliance programs
- Large customers translate these standards into **contractual requirements**, making them de-facto obligations for suppliers

As a result, many organizations implement NIST-aligned controls even when their primary legal trigger is a private-sector regulation such as HIPAA or GLBA.

Why US compliance is often harder to operationalize

A fragmented model creates a coordination problem:

- one product may serve healthcare, finance, and general consumers at once
- customers may require NIST or SOC 2 alignment even when the law does not explicitly say so
- states change faster than enterprise compliance programs
- engineering teams end up implementing the union of several regimes, not one clean rulebook

Standards, Frameworks, and Assurance



Laws, standards, and audits are not interchangeable

Laws and regulations

tell you what is mandatory,
prohibited, or reportable

Standards and frameworks

help structure controls,
governance, and evidence

Assurance artifacts

give customers, auditors,
or regulators a basis to
trust your claims

ISO/IEC 27001: management-system thinking

ISO/IEC 27001 is the international standard for Information Security Management Systems. Certification is issued by an accredited third-party auditor and is internationally recognized.

The **ISMS** (Information Security Management System) approach requires:

- **Context and scope:** understand the organization's environment, stakeholders, and boundaries
- **Risk assessment:** identify and evaluate information security risks systematically
- **Controls:** select appropriate controls from Annex A (114 controls across 14 domains in ISO 27001:2013; restructured in ISO 27001:2022)
- **Statement of Applicability (SoA):** document which controls apply and justify exclusions
- **Documented evidence:** policies, procedures, records, and audit trails
- **Continuous improvement:** internal audits, management reviews, and corrective actions

ISO 27001 helps demonstrate GDPR Art. 32 compliance (security of processing), but certification alone does not prove full GDPR compliance.

NIST CSF 2.0 is attractive because it is understandable

The **NIST CSF** (Cybersecurity Framework) 2.0 organizes security around six outcome-oriented functions that executives, auditors, and engineers can all use as a common language:

- **Govern** (*new in 2.0*): establish accountability, risk governance, and organizational context
- **Identify**: understand assets, systems, risks, and data dependencies
- **Protect**: deploy appropriate safeguards
- **Detect**: identify anomalies and security events
- **Respond**: contain and manage incidents
- **Recover**: restore capabilities and operations

The framework is **voluntary** for most organizations but widely referenced in contracts, insurance questionnaires, SEC disclosures, FISMA compliance, and regulatory due-diligence inquiries.

NIST CSF 2.0 is attractive because it is understandable

The **NIST CSF** (Cybersecurity Framework) 2.0 organizes security around six outcome-oriented functions that executives, auditors, and engineers can all use as a common language:

- **Govern** (*new in 2.0*): establish accountability, risk governance, and organizational context
- **Identify**: understand assets, systems, risks, and data dependencies
- **Protect**: deploy appropriate safeguards
- **Detect**: identify anomalies and security events
- **Respond**: contain and manage incidents
- **Recover**: restore capabilities and operations

The framework is **voluntary** for most organizations but widely referenced in contracts, insurance questionnaires, SEC disclosures, FISMA compliance, and regulatory due-diligence inquiries.

The explicit addition of **Govern** is important for regulation because many enforcement failures come from missing ownership, unclear reporting lines, and undocumented risk decisions, not from missing tools alone.

SOC 2 answers a customer-assurance question

SOC 2 (Service Organization Control 2) is an attestation standard governed by the **AICPA** (American Institute of Certified Public Accountants). Cloud and SaaS vendors use it because enterprise customers want third-party assurance that security, availability, and confidentiality controls are in place.

Key distinctions:

- **Type I**: controls are suitably *designed* at a specific point in time
- **Type II**: controls *operated effectively* over a period (usually 6–12 months) – far more meaningful
- SOC 2 is not a statute: a SOC 2 report does not prove GDPR, HIPAA, or NIS2 compliance
- Scope and control wording vary: a narrow scope can produce a clean report without covering real risks
- The five **Trust Services Criteria (TSC)**: Security (mandatory), Availability, Confidentiality, Processing Integrity, Privacy

The practical mapping

Layer	Main question	Example
Privacy regulation	May we process this data this way?	GDPR, CCPA/CPRA
Cyber regulation	Are we governing cyber risk adequately?	NIS2, DORA
Sector regulation	Do sector-specific duties apply?	HIPAA, GLBA
Framework	How should we structure controls?	NIST CSF
Standard / certification	How do we formalize and evidence a management system?	ISO 27001
Assurance report	How do we reassure customers?	SOC 2

What Compliance Looks Like in Practice



A realistic compliance workflow

1. Identify jurisdictions, sectors, products, and customers
2. Map systems, data flows, processors, and critical suppliers
3. Decide which legal regimes and standards apply
4. Run a gap analysis against those obligations
5. Implement policies, controls, contracts, and workflows
6. Test them through audits, tabletop exercises, and incident drills
7. Keep evidence that the controls actually operate

Roles must be separated but coordinated

Legal / privacy

- interpret obligations
- manage notices and contracts
- coordinate with regulators
- supervise data-subject processes

Security / engineering

- implement controls
- log and monitor systems
- manage vulnerabilities
- run incident response and recovery

Management

- allocate resources
- approve risk decisions
- demand evidence and reporting
- own accountability when the regime requires it

Regulators and auditors usually ask for evidence, not promises

Common evidence requests include:

- asset and data inventories
- retention schedules
- incident-response plans and records
- access-control reviews
- vendor due-diligence materials
- DPIAs or similar risk assessments
- training records
- board or management reporting artifacts

Incident reporting deadlines punish improvisation

Across GDPR, NIS2-like, DORA-like, and sector-specific regimes, the same operational lesson appears: deadlines are short, and they start before the organization feels ready.

So the difficult part is not drafting the notification template. The difficult part is having pre-agreed answers to:

- who decides whether an event is legally reportable?
- who owns the facts?
- who can speak for the organization?
- what evidence must be preserved immediately?

Incident reporting deadlines punish improvisation

Across GDPR, NIS2-like, DORA-like, and sector-specific regimes, the same operational lesson appears: deadlines are short, and they start before the organization feels ready.

So the difficult part is not drafting the notification template. The difficult part is having pre-agreed answers to:

- who decides whether an event is legally reportable?
- who owns the facts?
- who can speak for the organization?
- what evidence must be preserved immediately?

If those responsibilities are defined only during the incident, the organization is already late.

Takeaways



What you should retain from this lecture

- Regulation is a response to repeated, visible failures in privacy and cyber governance
- The legal map is layered: privacy, cybersecurity, sector, product, and assurance layers overlap
- The EU model is more unified and rights-oriented; the US model is more fragmented and sector-driven
- Standards such as ISO 27001 and NIST CSF help operationalize compliance, but do not replace legal analysis
- Good compliance work translates legal duties into system design, controls, workflows, and evidence